Module 8 · Activity

Set Up AI Governance at the University of Petra

ISO/IEC 42001 and Governance Structure · a fictional scenario

307307 BI Methods for Generative AI · AI Governance · University of Petra

Group name	
Members	
Date	

How this activity works

- Work in groups of 3–4. Type your answers directly into the boxes.
- There is no single right answer. What matters is that you can explain each choice.
- **Suggested time:** Part A 10 min · Part B 15 min · Part C 15 min · Part D 10 min · Part E 10 min. Your lecturer may adjust this.
- Use the lecture slides to check a term. Rows shaded in green are worked examples.

The scenario (fictional)

The University of Petra now uses AI in several places, but nobody is in charge of it. The president asks you to form the AI governance team and to prepare for ISO/IEC 42001 certification within two years.

The four AI systems in use today

- **Admissions Ranker:** scores and ranks applicants. Bought from a vendor. Run by the Admissions Office.
- **Study Buddy:** a student chatbot about registration and exams. Bought from a vendor. Run by IT Services.
- **CourseMatch:** suggests elective courses. Built by the university's IT team.
- **PromoStudio:** makes marketing images and videos with AI. Built by the Communications team.

What exists already

- An information security management system that is certified to ISO/IEC 27001, with its own security committee and internal audit program.
- No AI policy, no AI inventory and no named owners for AI systems.

Part A · Judge the audit evidence

An auditor asks each team to prove that its AI governance works. For each answer, decide whether it is acceptable evidence or a finding (a problem), and say why.

What the team says or shows	OK or finding?	Why? What evidence is missing or good?
Example: "We have an AI risk policy, approved by the board." No risk assessments can be shown.	**Finding**	A policy alone is not enough. The auditor needs risk assessments, treatment plans and proof that controls run.
"Our AI inventory lists Admissions Ranker and Study Buddy." CourseMatch and PromoStudio are not on it.		
"Study Buddy's owner is the Dean of Student Affairs. Here is the signed role description, and she can explain it."		
"We train our models carefully." No monitoring reports or test results can be shown.		
"A student got a wrong exam date from the chatbot in March. Here is the incident record, the investigation and the fix we tested."		
"Internal audit runs Admissions Ranker for us, and also checks it."		

Hint: ask whether there is objective evidence, whether roles are clear, and whether audit is independent.

Part B · Statement of Applicability

For five Annex A control areas, decide whether each applies to the university's AI systems. Give a reason, and say how it is implemented (or why it is excluded).

Annex A control area	Applies?	Reason, and how it is implemented
Example: Third-party AI	**Yes**	Two systems are bought. We assess each vendor's security, privacy and contract terms before signing.

Choose from: governance and accountability · AI risk management · data governance · AI lifecycle management · transparency and explainability · human oversight · security and resilience · monitoring and logging · incident management · third-party AI. A control may be excluded only if the risk it covers does not exist, and you must say why.

Part C · Fill the RACI matrix

Mark each box with R, A, C or I, or leave it blank if the role is not involved. Each activity must have exactly one A.

Activity	Senior mgmt	AI committee	AI GRC officer	System owner	IT and security	Internal audit
Example: Approve the Admissions Ranker for use	**A**	**R**	**C**	**C**	**C**	**I**
Maintain the AI inventory						
Monitor Study Buddy's answers						
Manage an incident (wrong exam date)						
Check legal and privacy rules for applicant data						
Independent review of the whole AI governance system						

R = does the work · A = accountable, owns the outcome · C = consulted · I = informed.

Question	Your answer
Which existing group could take on the AI governance committee role? Why?	
If the system owner and the legal office disagree about launching a system, who decides?	

Part D · Start the AI inventory

Fill in the inventory for the four systems. Use the EU AI Act risk levels from Module 7 (Prohibited, High, Limited or Minimal). Name an owner by job title, not a person's name.

System	Owner (job title)	Provider	Data used	Risk level	Status and notes
Example: Library recommender	Head librarian	In-house	Loan history	**Minimal**	In use. Review yearly.
Admissions Ranker					
Study Buddy					
CourseMatch					
PromoStudio					

Which system should the committee review first, and why?

Part E · Policy essentials

Choose five elements of an AI governance policy. For each, write one requirement that starts with “The university will…”.

> **Policy elements:** purpose and objectives · scope · principles · roles and responsibilities · AI risk management · use-case governance · data governance · model and system governance · human oversight · third-party governance · security · compliance · incident management · records · training · monitoring and review · exceptions · approval and review.

Policy element	The university will…
Example: Incident management	The university will record every AI incident, investigate it, and report serious incidents to the AI governance committee within five working days.

Reflection

How could the university reuse its ISO/IEC 27001 system for AI governance?	
Which of the common pitfalls is the university most at risk of, and why?	

This scenario is fictional and is not based on any real university system.